

My Book Notes

Part I – Foundations of Identity-Centric Security

- Chapter 1 – Foundations of Federal and Military Identity-Centric Security: Active Directory (AD), FICAM, and the Modern Directory Services Enterprise
- Chapter 2 – Federal Identity, Credential, and Access Management (FICAM): Identity Governance Across Federal, Defense, and Command Combatant Mission Environments
- Chapter 3 – Enterprise Identity Infrastructure – Networking, Directory Services, Authentication Protocols, and Active Directory Architecture
- Chapter 4 – Active Directory and FICAM Security Assessment Methodologies: Planning, Scoping, and Operational Preparation

I decided to introduce Parts into the book. They provide clear milestones for readers while reinforcing the progression from foundational concepts to assessment methodology, offensive operations, defensive operations, and future directions. My proposed structure is as follows:

- Part I – Foundations of Identity-Centric Security (Chapters 1-4)
- Part II – Identity Assessment and Defensive Foundations (Chapter 5)
- Part III – Identity Attack Operations (Chapters 6-12)
- Part IV – Detection, Response, Recovery, and the What the Future Holds for Identity Security (Chapters 13-16)

Federal Civilian Agencies

Commonly reference:

- NIST SP 800-53
- NIST SP 800-63
- NIST RMF
- FICAM
- CISA Guidance
- OMB Memoranda
- FedRAMP (cloud)

Department of Defense

Typically emphasize:

- RMF
- NIST SP 800-53 (tailored through DoD policy)
- DISA STIGs and SRGs
- DoD Zero Trust Reference Architecture
- DoD CIO Guidance
- CNSSI (where applicable)
- NSA Hardening Guidance
- USCYBERCOM Guidance (where applicable and publicly available)

Commercial Enterprise

Often use:

- CIS Benchmarks
- Microsoft Security Baselines
- ISO/IEC 27001
- CIS CSC
- NIST CSF

Standards, Frameworks, and Guidance Covered

- Microsoft Security Baselines
- Microsoft Enterprise Access Model

- DISA Windows Server STIG
- DISA Active Directory STIG
- DISA PKI STIG
- Security Requirements Guides (SRGs)
- NIST SP 800-53
- NIST SP 800-63
- NIST SP 800-37 (NIST RMF)
- NIST SP 800-207
- FICAM Architecture Framework
- CISA Cross-Sector Cybersecurity Performance Goals (for broader context)
- DoD Zero Trust Reference Architecture
- NSA Best Practices for Active Directory (where appropriate)

Since this book is centered on Active Directory within federal and military environments, the hierarchy of authoritative guidance should be:

1. NIST (foundational cybersecurity and identity guidance)
2. FICAM (federal identity governance)
3. DISA STIGs / SRGs (DoD implementation guidance)
4. Microsoft (platform-specific implementation guidance)
5. CISA (operational and strategic cybersecurity guidance)
 - o The Continuous Diagnostics and Mitigations (CDM) program provides cybersecurity tools and services to federal agencies.
 - o CISA issues "binding operational directives" that require federal government agencies to take action against specific cybersecurity risks.
 - o In March 2021, CISA assumed control of the .gov top-level domain (TLD) from the General Services Administration. CISA manages the approval of domains and operates the TLD Domain Name System nameservers. In April 2021, CISA removed the fee for registering domains.
 - o In January 2023, Cloudflare received a \$7.2M contract to provide DNS registry and hosting services for the TLD.
 - o CISA provides incident response services to the federal executive branch and US-based entities.
 - o CISA manages the EINSTEIN intrusion detection system to detect malicious activity on federal government agency networks.
 - o The National Defense Authorization Act for Fiscal Year 2021 granted CISA the authority to issue administrative subpoenas to identify the owners of internet connected critical infrastructure related devices with specific vulnerabilities. In 2021, CISA issued 47 subpoenas.
 - o In 2021, CISA released a report that provided guidance for how to navigate and prevent ransomware incidents. This was due to a significant jump in recent attacks related to ransomware.

6. MITRE ATT&CK / D3FEND (adversary and defensive TTP knowledge bases)

This layout will further distinguish the book from generic Active Directory texts. Instead of saying "Here's what everyone uses," it's saying "Here's the guidance hierarchy that federal agencies, defense organizations, and mission environments actually rely on." This makes the content more authentic for the audience I'm targeting.

Federal and military entities utilize a tiered set of security baselines. The foundation for all federal mandated security is the NIST SP 800-53 control catalog, which mandates High, Moderate, and Low baselines. Civilian agencies, on the other hand, use CISA's SCuBA framework, while DoD uses strict DISA STIG and SRGs for

hardware/software hardening.

The DoD and Federal Government mandate several distinct compliance and security control configuration baselines:

1. Cloud & Enterprise Baselines

- FedRAMP: A term used for the mandatory baseline combined with additional, specialized security overlays, required by the DoD or Intelligence Community (IC). FedRAMP is the universal baseline for commercial Cloud Service Providers (CSPs). It classifies data by potential impact level:

- o Low/Moderate: Used for public-facing or internal agency data.
- o High: For the government's most sensitive, unclassified data

- DoD Cloud Computing Security Requirements Guide (SRG): Builds on FedRAMP by layering defense-specific controls and mandates.

- o Impact Levels (IL): DoD cloud deployments span from L2 (Public) to IL4/IL5 (Controlled Unclassified Information (CUI) and Mission-Critical Data) up to IL6 (Secret).

2. Device & Configuration Baselines

- o Security Technical Implementation Guides (STIGs): The definitive cybersecurity standard used by the DoD, DISA, and the Intelligence Community to secure network devices, software, and operating systems.

- o United States Government Configuration Baseline (USGCB): A federal, government-wide initiative designed to standardize security configuration settings on IT products across civilian agencies.

- o CISA Secure Configuration Baselines: Agency-issued guidelines tailored specifically to cloud-based business applications (like Microsoft 365) to protect Federal Civilian Executive Branch (FCEB) assets.

3. Overarching Architectural Frameworks

- o Risk Management Framework (RMF): The mandatory process for managing cybersecurity risk across the DoD, IAW NIST. It is mandated by DoDI 8510.01.

- o Zero Trust Architecture (ZTA): Both the DoD and CISA have migrated to Zero Trust, assuming no implicit trust is granted to any user or asset regardless of location. These principles are enforced across DoD networks as outlined in the DoD Zero Trust Reference Architecture documentation.

4. Military Branches: Navy, Marine Corps, Army, Air Force, and Space Force
While individual military branches must strictly comply with overarching DoD requirements (like DISA STIGs, and RMF), each branch overlays its own tailored security baselines to address their unique operational environments – whether on land, at sea, or in the air.

4.1 Department of the Navy (USN) & United States Marine Corps (USMC)

The Navy and Marine Corps focus heavily on securing afloat networks (ships and submarines) operating with limited or intermittent bandwidth, shifting away from “point-in-time” compliance toward a continuous, consistent security posture.

- o “Cyber Ready” & Cyber Currency: The Department of Navy (DON) Chief Information Officer (CIO) Cyber Ready initiative replaces traditional, bureaucratic static assessments. Programs must maintain “Cyber Currency” through continuous automated penetration testing and Breach and Adversarial Security Assessments (BAS).

- o Afloat Cyber Baselines (FRD 300): Managed by NAVWAR, this framework ensures that tactical shipboard networks – such as the Consolidated Afloat Networks and Enterprise Services (CANES) – strictly comply with naval cybersecurity technical authority standards before production deployments.
- o Flank Speed & Flank Speed Mercury: The Navy’s baseline cloud enterprise environment, which enforces a Zero Trust architecture across unclassified and classified networks.

4.2 Department of the Air Force (USAF & USSF)

The Air Force and Space Force prioritize rapid software deployment at the tactical edge (such as in-flight fighter jets or orbiting satellites) and are aggressively modernizing legacy infrastructure.

- o Platform One: The Air Force’s premier, managed DevSecOps enterprise team. It provides pre-hardened Kubernetes and containerized security baselines, allowing software platforms to achieve continuous Authority to Operate (cATO).
- o Network of the Future Strategy: Issued by the DAF CIO, this framework sets the security baseline standard for integrating commercial encrypted networking technologies into military digital infrastructure.
- o DAFGM 2024-32 (Control Systems): A specialized baseline directive that tailor’s cybersecurity specifically to Operational Technologies (OT) and civil engineering infrastructure, prioritizing availability and integrity over standard IT confidentiality.

4.3 Department of the Army (USA)

The Army emphasizes securing tactical communications networks for soldiers on the move and standardizing software factories.

- o Army Software Factory & DevSecOps Playbook: Establishes the secure baselines for building custom, cloud-native tools. It uses automated “security control gates” to continuously vet code before field deployments.
- o Unified Network Plan: The operational baseline designed to converge the Army’s disparate technical (battlefield) and enterprise (garrison) networks into a single, highly secure Zero Trust architecture.

Addressing Reader Audience

The audience is not just “federal.” There are multiple identity ecosystems with different authoritative guidance:

- Federal Civilian Executive Branch (FCEB)
- Department of Defense
- Intelligence Community
- Military Departments
- Defense Contractors (through DFARS/CMMC where applicable)

Those communities all share NIST as a foundation, but they diverge significantly in implementation guidance.

I think I should change the philosophy of the book

Rather than saying: “These are the standards.”

I should say: “These are the applicable standards depending on the mission environment.”

This is a much more accurate representation of the realities.

Identity Security Baselines by Mission Environment

Mission Environment	Primary Baseline Authority	Supporting Guidance
Federal Civilian Executive Branch (FCEB)	NIST SP 800-53	CISA SCuBA, FICAM,

OMB, Zero Trust Strategy

Department of Defense NIST SP 800-53 + NIST SP 800-37, Revisions 1 & 2 (NIST RMF for DoD) DISA STIGs, SRGs, DoD Zero Trust Reference Architecture
Intelligence Community (IC) CNSS/CNSSI, ICD guidance, NIST IC overlays, mission-specific directives
Cloud Service Providers (CSPs) Supporting Government Entities FedRAMP (federal), Cloud Security Alliance (CSA; commercial) Agency overlays; DoD Cloud STIG and SRG (available for public use)
DoD Cloud DoD Cloud STIG and SRG Impact Levels (IL2-IL6); FedRAMP inheritance
Enterprise Commercial Microsoft Security Baselines, CIS CSC, OWASP Top 10 CIS (where adopted); security vendor guidance

The table above distinguishes between individual mission sets rather than implying one universal baseline.